

Under the Shadow of Sunshine: Understanding and Detecting Bulletproof Hosting on Legitimate Service

Problem Statement

The paper investigates the emerging trend of Bulletproof Hosting (BPH) services leveraging lower-end service providers to evade detection. Traditionally, BPH services operated within dedicated malicious Autonomous Systems (ASes), making them easy to blacklist. However, they have now started reselling infrastructure from legitimate providers (e.g., hosting ISPs, cloud services, and CDNs), blending in with benign clients. Paper also aims to detect these sub-allocations with high accuracy.

Assumptions

One big assumption of this paper is that it assumes that malicious clients frequently migrate between sub-allocations, which is reflected in the short lifespan of domains and high IP churn rates. This assumption is crucial for identifying BPH activities but might not apply to long-term malicious operations.

Pros

- High Detection Accuracy: The classifier achieved 98% recall and 1.5% false discovery rate, demonstrating effectiveness in detecting malicious network blocks.
- Innovative Feature Selection: New detection features, such as DNS churn and sub-allocation behavior, make it costly for BPH services to evade detection.
- Scalable Detection Method: The classifier can efficiently scan the entire IPv4 address space to identify malicious sub-allocations.

Cons

- Limited Ground Truth Data: Due to the lack of comprehensive labeled datasets, the model relies on a combination of blacklists, which introduce bias.
- Updation of the model: Over time, BPH operators may adapt, reducing the effectiveness of the classifier, hence it might need to be trained again on new data.
- Reliance on Whois Data: The approach depends on accurate and up-to-date Whois records, which some providers may intentionally obfuscate.